

# LAPORAN VULNERABILITY ASSESSMENT

## NESSUS ESSENTIALS

Target: Metasploitable 2 | Lab Internal

|             |                                             |
|-------------|---------------------------------------------|
| Target IP   | 192.168.56.105                              |
| Scanner     | Nessus Essentials (Free)                    |
| Platform    | 127.0.0.1:8834 (Local Scanner - Kali Linux) |
| Tanggal     | 12-13 Mei 2025                              |
| Dibuat Oleh | Fahmi Riansyah (fahmipentest)               |
| Project     | Project Meta2                               |
| Klasifikasi | CONFIDENTIAL - Lab Internal Pentest         |

DISCLAIMER: Laporan ini dibuat semata-mata untuk keperluan latihan di lingkungan lab terkontrol (home lab). Target adalah VM yang sengaja dibuat rentan. Tidak ada sistem production yang diuji.

# 1. RINGKASAN EKSEKUTIF

Laporan ini mendokumentasikan hasil Vulnerability Assessment (VA) menggunakan Nessus Essentials versi gratis terhadap Metasploitable 2 dalam lingkungan lab terkontrol. Metasploitable 2 adalah VM Linux yang sengaja dikonfigurasi dengan banyak kerentanan untuk keperluan latihan penetration testing.

Keseluruhan pengujian dilakukan dari mesin Kali Linux dengan Nessus Essentials yang berjalan di 127.0.0.1:8834, menyasar target 192.168.56.105 melalui jaringan Host-Only VirtualBox.

## 1.1 Ringkasan Temuan Keseluruhan

| Scan Name                   | Critical | High | Medium | Low | Info     |
|-----------------------------|----------|------|--------|-----|----------|
| Host Discovery              | -        | -    | -      | -   | 3 (Info) |
| Basic Network Scan (metas2) | 10       | 9    | 40     | 11  | 173      |
| Advanced Scan               | 11       | 9    | 34     | 13  | 167      |
| Web Application Tests       | 4        | 4    | 18     | -   | 67       |

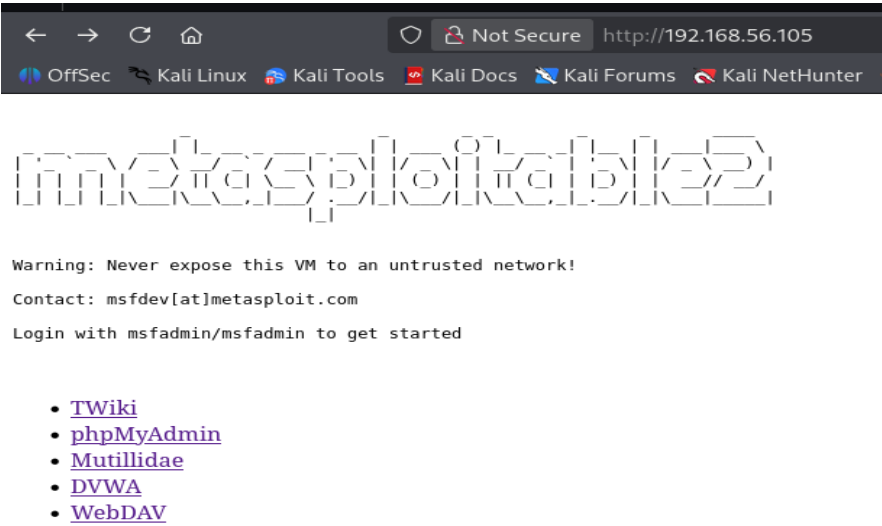
Hasil pengujian menunjukkan target memiliki kerentanan sangat parah pada semua lapisan: OS yang sudah EOL, layanan jaringan usang tanpa enkripsi, backdoor aktif, kredensial default, dan kerentanan web komprehensif.

## 2. LINGKUNGAN PENGUJIAN

### 2.1 Konfigurasi Lab

|                |                                          |
|----------------|------------------------------------------|
| Scanner Tool   | Nessus Essentials (Free) - Tenable       |
| Scanner Host   | Kali Linux - 127.0.0.1:8834              |
| Target VM      | Metasploitable 2 (Ubuntu Linux 8.04 LTS) |
| Target IP      | 192.168.56.105                           |
| Jaringan       | Host-Only Network (VirtualBox)           |
| Severity Basis | CVSS v3.0                                |
| Project Nessus | Project Meta2                            |

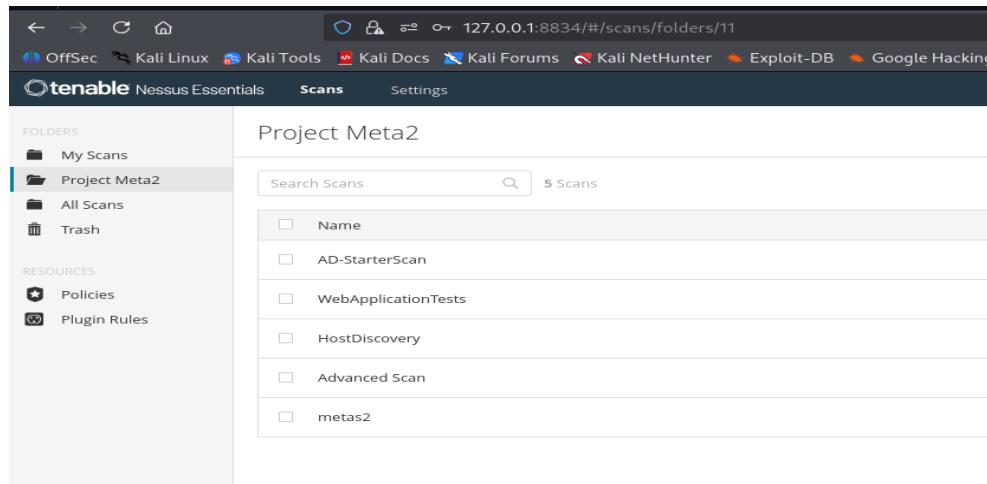
### 2.2 Target: Metasploitable 2



Gambar 1 - Welcome page Metasploitable 2 diakses dari browser Kali Linux

Metasploitable 2 menyediakan berbagai layanan yang dapat diuji, antara lain TWiki, phpMyAdmin, Mutillidae, DVWA (Damn Vulnerable Web App), dan WebDAV. Semua layanan ini dikonfigurasi dengan kerentanan yang diketahui untuk keperluan latihan.

### 2.3 Daftar Scan dalam Project Meta2



Gambar 2 - Project Meta2 berisi 5 scan yang dikonfigurasi di Nessus Essentials

Terdapat 5 scan dalam folder Project Meta2: AD-StarterScan, WebApplicationTests, HostDiscovery, Advanced Scan, dan metas2 (Basic Network Scan).

## 2.4 Keterbatasan Nessus Essentials (Free)

- Maksimal 16 IP address yang dapat discan
- Fitur export laporan ke PDF/XML/CSV tidak tersedia secara penuh (hanya tersedia di Nessus Professional/Expert)
- Tidak ada compliance checks (PCI DSS, CIS, HIPAA, dll.)
- Tidak mendukung scheduled scans dan agent-based scanning
- Karena keterbatasan export, laporan ini disusun manual berdasarkan screenshot

### 3. METODOLOGI

#### 3.1 Tahapan Pengujian

Pengujian dilakukan secara bertahap dengan empat tipe scan Nessus yang berbeda tingkat kedalamannya:

| No. | Tipe Scan          | Deskripsi                                                                | Durasi  | Policy                |
|-----|--------------------|--------------------------------------------------------------------------|---------|-----------------------|
| 1   | Host Discovery     | Identifikasi host aktif, port terbuka, OS detection dasar                | 7 menit | Host Discovery        |
| 2   | Basic Network Scan | Scan jaringan standar untuk kerentanan umum dan service detection        | 4 jam   | Basic Network Scan    |
| 3   | Advanced Scan      | Scan mendalam dengan lebih banyak plugin aktif dan thorough inspection   | 1 jam   | Advanced Scan         |
| 4   | Web App Tests      | Fokus pada kerentanan web: XSS, LFI, RFI, Path Traversal, dan CGI issues | 7 jam   | Web Application Tests |

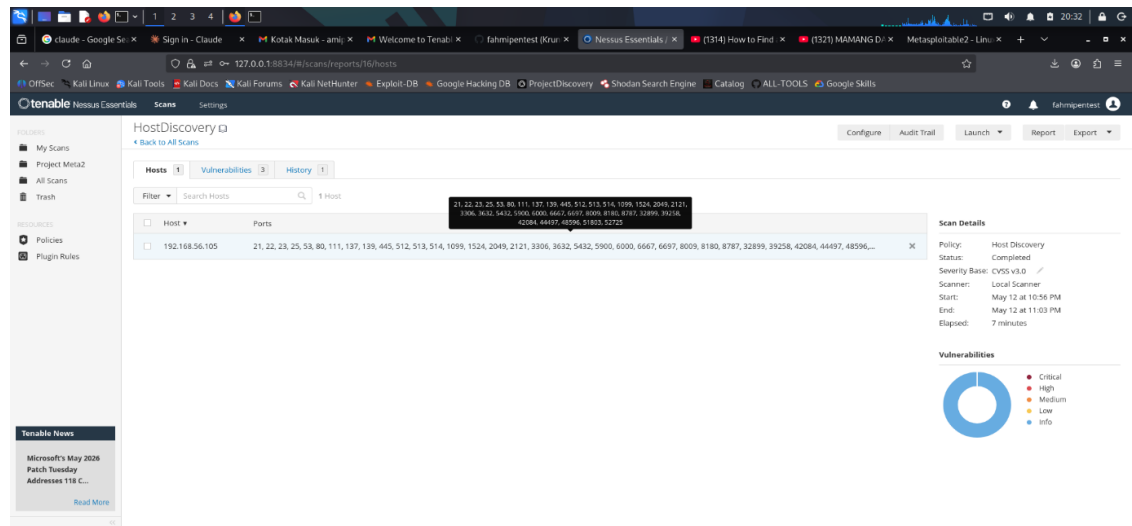
#### 3.2 Skala Severity CVSS v3.0

| Severity | CVSS Score | Deskripsi                                                       |
|----------|------------|-----------------------------------------------------------------|
| CRITICAL | 9.0 - 10.0 | Kerentanan kritis, dapat dieksploitasi penuh tanpa autentikasi  |
| HIGH     | 7.0 - 8.9  | Kerentanan serius yang dapat menyebabkan kompromi sistem        |
| MEDIUM   | 4.0 - 6.9  | Kerentanan yang memerlukan kondisi tertentu untuk dieksploitasi |
| LOW      | 0.1 - 3.9  | Kerentanan dengan dampak minimal                                |
| INFO     | N/A        | Informasi tambahan, bukan kerentanan langsung                   |

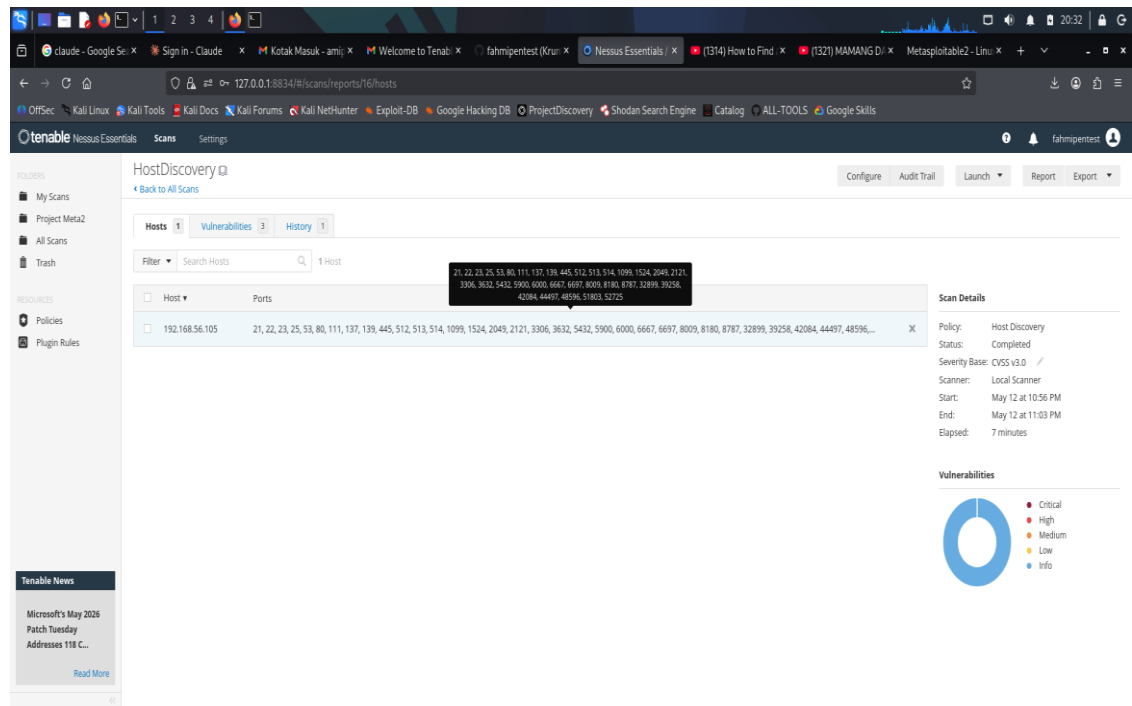
## 4. HASIL SCAN: HOST DISCOVERY

|                |                               |
|----------------|-------------------------------|
| Policy         | Host Discovery                |
| Status         | Completed                     |
| Start          | May 12 at 10:56 PM            |
| End            | May 12 at 11:03 PM            |
| Elapsed        | 7 menit                       |
| Scanner        | Local Scanner (Kali Linux)    |
| Severity Base  | CVSS v3.0                     |
| Host Ditemukan | 1 host aktif (192.168.56.105) |

### 4.1 Screenshot Hasil Scan



Gambar 3 - Host Discovery: overview hasil scan dengan scan details panel



Gambar 4 - Host Discovery: list port terbuka pada host 192.168.56.105

## 4.2 Port yang Ditemukan

### PORT TERBUKA PADA 192.168.56.105

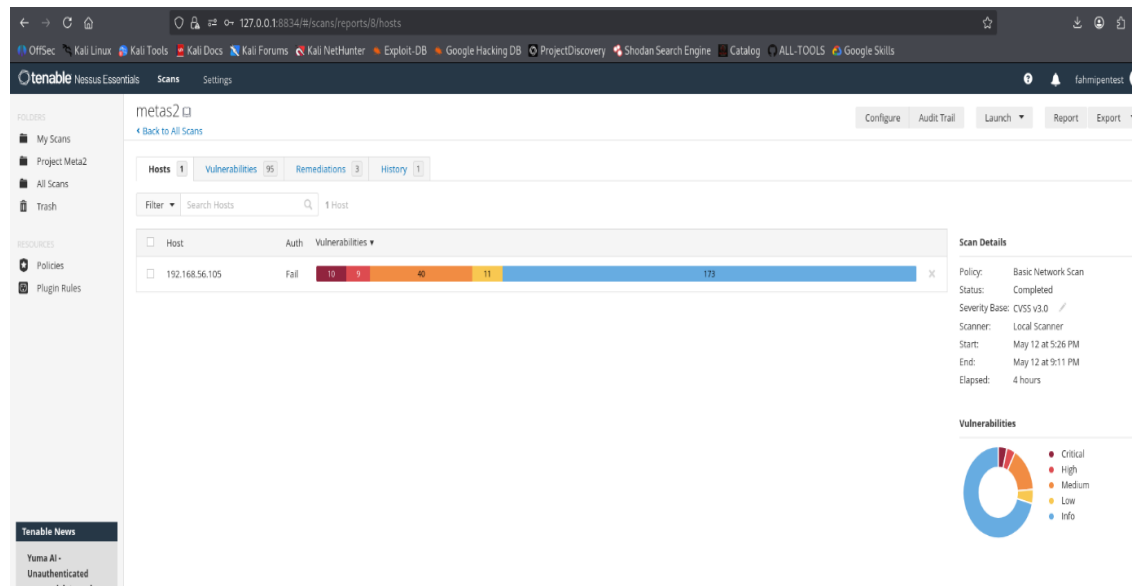
21 (FTP), 22 (SSH), 23 (Telnet), 25 (SMTP), 53 (DNS), 80 (HTTP), 111 (RPC), 137 (NetBIOS-NS), 139 (NetBIOS-SSN), 445 (SMB), 512 (rexec), 513 (rlogin), 514 (rsh), 1099 (RMI), 1524 (Ingreslock/Backdoor), 2049 (NFS), 2121 (FTP-alt), 3306 (MySQL), 3632 (distcc), 5432 (PostgreSQL), 5900 (VNC), 6000 (X11), 6667 (IRC), 6697 (IRC-SSL), 8009 (AJP), 8180 (HTTP-alt/Tomcat), 8787 (msfconsole), 32899, 39258, 42084, 44497, 48596, 51803, 52725

Host Discovery mengungkap attack surface yang sangat luas dengan 34+ port terbuka. Temuan mencolok antara lain: port 23 (Telnet - plaintext), port 514 (rsh - no auth), port 1524 (backdoor shell), port 5900 (VNC), port 8787 (Metasploit RPC).

## 5. HASIL SCAN: BASIC NETWORK SCAN (metas2)

|                 |                             |
|-----------------|-----------------------------|
| Policy          | Basic Network Scan          |
| Status          | Completed                   |
| Start           | May 12 at 5:26 PM           |
| End             | May 12 at 9:11 PM           |
| Elapsed         | 4 jam                       |
| Scanner         | Local Scanner               |
| Authentication  | Fail (Unauthenticated Scan) |
| Unique Findings | 95 vulnerabilities          |

### 5.1 Ringkasan Vulnerability

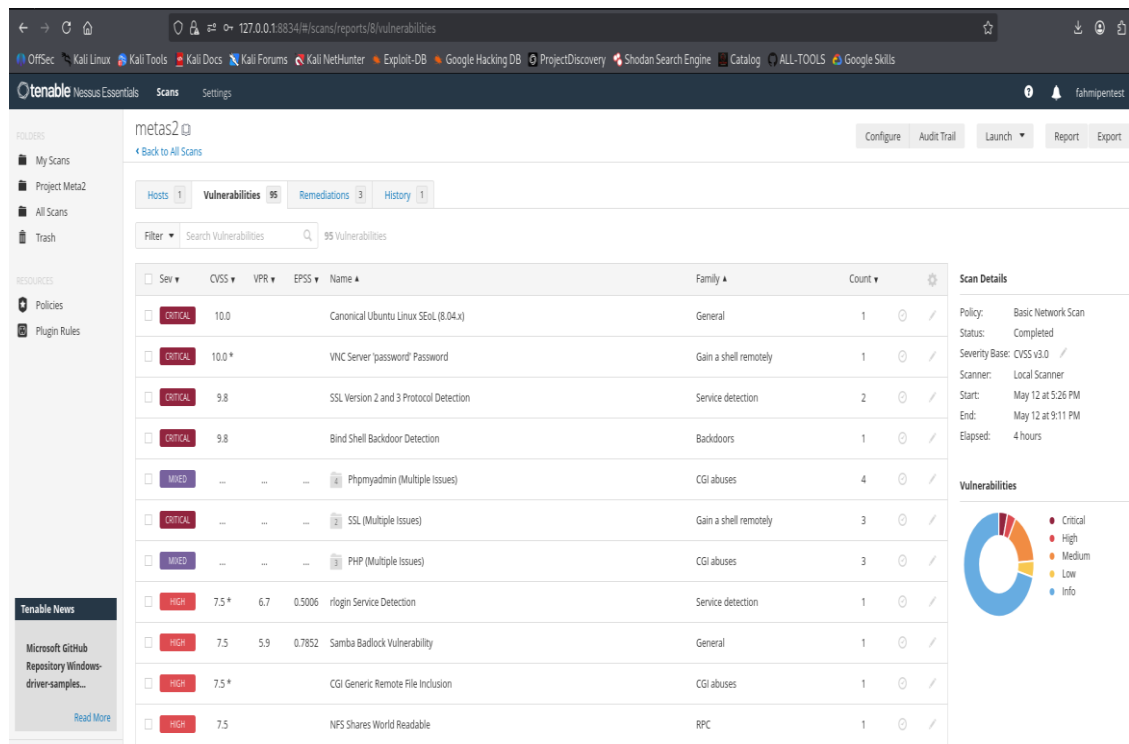


Gambar 5 - Basic Network Scan: vulnerability severity bar untuk 192.168.56.105

|          |      |        |     |      |
|----------|------|--------|-----|------|
| Critical | High | Medium | Low | Info |
| 10       | 9    | 40     | 11  | 173  |

### 5.2 Detail Kerentanan Utama





Gambar 6 - Basic Network Scan: daftar 95 vulnerability diurutkan berdasarkan severity

| Severity | CVSS  | Vulnerability                          | Family                | Count |
|----------|-------|----------------------------------------|-----------------------|-------|
| CRITICAL | 10.0  | Canonical Ubuntu Linux SEoL (8.04.x)   | General               | 1     |
| CRITICAL | 10.0  | VNC Server "password" Password         | Gain a shell remotely | 1     |
| CRITICAL | 9.8   | SSL Version 2 and 3 Protocol Detection | Service detection     | 2     |
| CRITICAL | 9.8   | Bind Shell Backdoor Detection          | Backdoors             | 1     |
| CRITICAL | Mixed | SSL (Multiple Issues)                  | Gain a shell remotely | 3     |
| HIGH     | 7.5   | rlogin Service Detection               | Service detection     | 1     |
| HIGH     | 7.5   | Samba Badlock Vulnerability            | General               | 1     |
| HIGH     | 7.5   | CGI Generic Remote File Inclusion      | CGI abuses            | 1     |
| HIGH     | 7.5   | NFS Shares World Readable              | RPC                   | 1     |
| MIXED    | ...   | Phpmyadmin (Multiple Issues)           | CGI abuses            | 4     |
| MIXED    | ...   | PHP (Multiple Issues)                  | CGI abuses            | 3     |

## 5.3 Penjelasan Vulnerability Kritis

### a) Ubuntu Linux 8.04 EOL - CVSS 10.0

Ubuntu 8.04 sudah End-of-Life sejak April 2013 dan tidak mendapat security patch. Ini berarti ratusan CVE yang sudah dipublish dapat dieksploitasi tanpa ada patch tersedia.

### b) VNC Server Password "password" - CVSS 10.0

VNC dikonfigurasi dengan password default "password". Penyerang dapat langsung melakukan remote takeover desktop tanpa usaha brute-force yang berarti.

### c) SSL v2/v3 Protocol Detection - CVSS 9.8

SSL v2 dan v3 rentan terhadap POODLE dan DROWN attack. Protokol ini memungkinkan man-in-the-middle attack dan dekripsi traffic yang seharusnya terenkripsi.

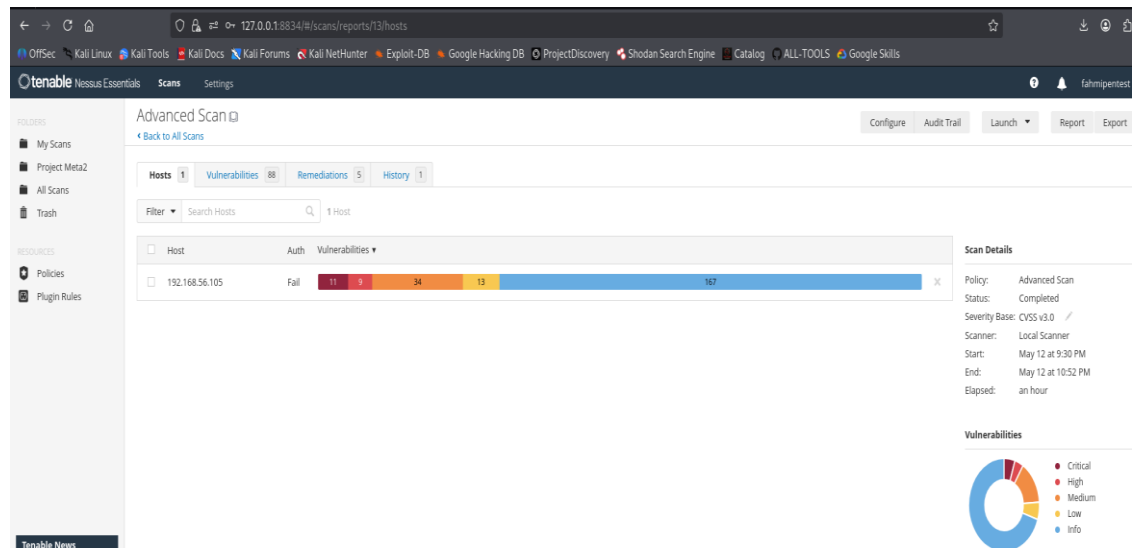
**d) Bind Shell Backdoor - CVSS 9.8**

Port 1524 memiliki bind shell yang memberikan akses root langsung tanpa autentikasi. Siapapun yang connect ke port ini akan mendapat shell dengan hak akses root.

## 6. HASIL SCAN: ADVANCED SCAN

|                 |                             |
|-----------------|-----------------------------|
| Policy          | Advanced Scan               |
| Status          | Completed                   |
| Start           | May 12 at 9:30 PM           |
| End             | May 12 at 10:52 PM          |
| Elapsed         | Kurang lebih 1 jam          |
| Scanner         | Local Scanner               |
| Authentication  | Fail (Unauthenticated Scan) |
| Unique Findings | 88 vulnerabilities          |

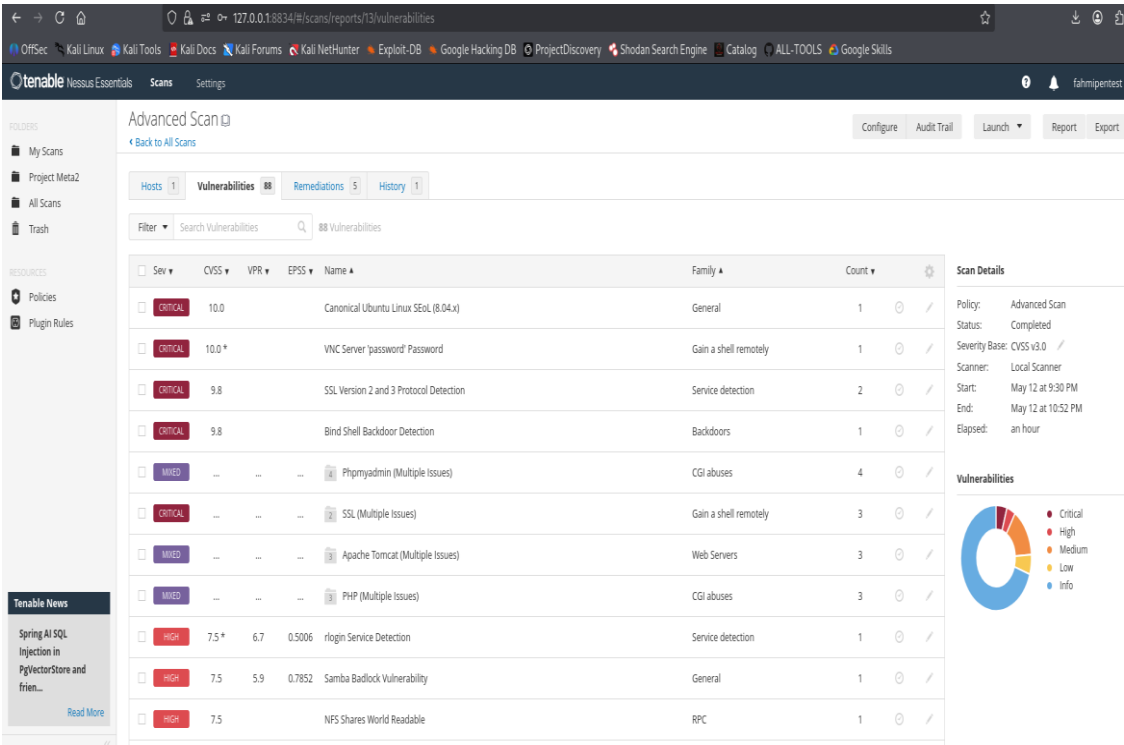
### 6.1 Ringkasan Vulnerability



Gambar 7 - Advanced Scan: vulnerability bar dan scan details panel

| Critical | High | Medium | Low | Info |
|----------|------|--------|-----|------|
| 11       | 9    | 34     | 13  | 167  |

### 6.2 Detail Kerentanan Utama



Gambar 8 - Advanced Scan: daftar vulnerability dengan CVSS, VPR, dan EPSS score

| Severity | CVSS  | Vulnerability                          | Family                | Count |
|----------|-------|----------------------------------------|-----------------------|-------|
| CRITICAL | 10.0  | Canonical Ubuntu Linux SEoL (8.04.x)   | General               | 1     |
| CRITICAL | 10.0  | VNC Server "password" Password         | Gain a shell remotely | 1     |
| CRITICAL | 9.8   | SSL Version 2 and 3 Protocol Detection | Service detection     | 2     |
| CRITICAL | 9.8   | Bind Shell Backdoor Detection          | Backdoors             | 1     |
| CRITICAL | Mixed | SSL (Multiple Issues)                  | Gain a shell remotely | 3     |
| MIXED    | ...   | Apache Tomcat (Multiple Issues)        | Web Servers           | 3     |
| MIXED    | ...   | Phpmyadmin (Multiple Issues)           | CGI abuses            | 4     |
| MIXED    | ...   | PHP (Multiple Issues)                  | CGI abuses            | 3     |
| HIGH     | 7.5   | rlogin Service Detection               | Service detection     | 1     |
| HIGH     | 7.5   | Samba Badlock Vulnerability            | General               | 1     |
| HIGH     | 7.5   | NFS Shares World Readable              | RPC                   | 1     |

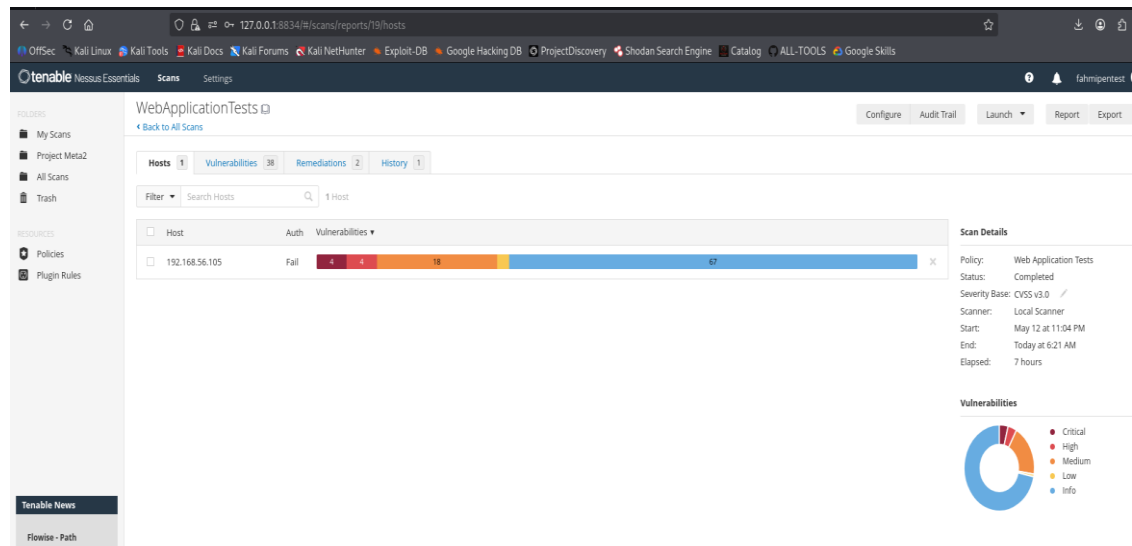
6.3 Perbedaan Advanced vs Basic Scan

- Advanced Scan menemukan lebih banyak Critical (11 vs 10) meskipun total finding lebih sedikit (88 vs 95)
- Advanced Scan mendeteksi Apache Tomcat Multiple Issues yang tidak muncul di Basic Scan
- Advanced Scan jauh lebih efisien: hanya 1 jam vs 4 jam untuk Basic Scan
- Jumlah Medium lebih rendah di Advanced Scan (34 vs 40) karena deduplication plugin yang lebih baik
- Advanced Scan memiliki 5 rekomendasi remediasi vs 3 di Basic Scan

## 7. HASIL SCAN: WEB APPLICATION TESTS

|                 |                             |
|-----------------|-----------------------------|
| Policy          | Web Application Tests       |
| Status          | Completed                   |
| Start           | May 12 at 11:04 PM          |
| End             | May 13 at 6:21 AM           |
| Elapsed         | 7 jam                       |
| Scanner         | Local Scanner               |
| Authentication  | Fail (Unauthenticated Scan) |
| Unique Findings | 38 vulnerabilities          |

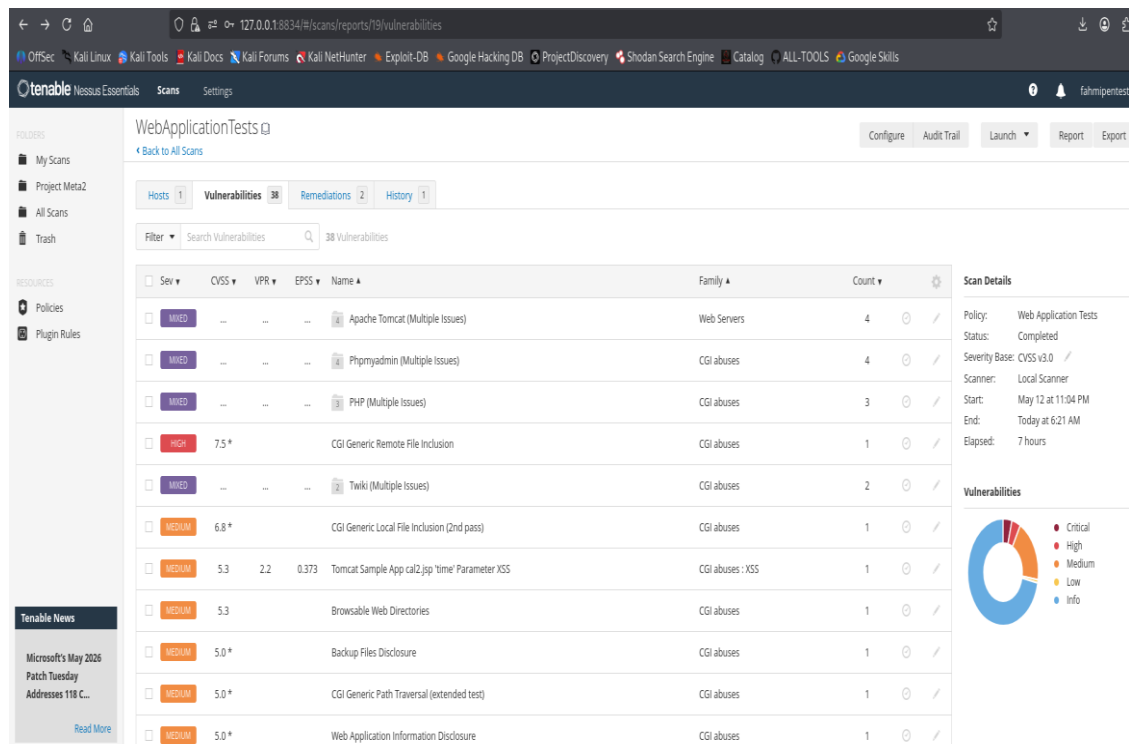
### 7.1 Ringkasan Vulnerability



Gambar 9 - Web Application Tests: overview severity dan scan details

| Critical | High | Medium | Low | Info |
|----------|------|--------|-----|------|
| 4        | 4    | 18     | -   | 67   |

### 7.2 Detail Kerentanan Web



Gambar 10 - Web Application Tests: daftar kerentanan web application

| Severity | CVSS | Vulnerability                           | Family          | Count |
|----------|------|-----------------------------------------|-----------------|-------|
| MIXED    | ...  | Apache Tomcat (Multiple Issues)         | Web Servers     | 4     |
| MIXED    | ...  | Phpmyadmin (Multiple Issues)            | CGI abuses      | 4     |
| MIXED    | ...  | PHP (Multiple Issues)                   | CGI abuses      | 3     |
| MIXED    | ...  | Twiki (Multiple Issues)                 | CGI abuses      | 2     |
| HIGH     | 7.5  | CGI Generic Remote File Inclusion (RFI) | CGI abuses      | 1     |
| MEDIUM   | 6.8  | CGI Generic Local File Inclusion (LFI)  | CGI abuses      | 1     |
| MEDIUM   | 5.3  | Tomcat Sample App cal2.jsp "time" XSS   | CGI abuses: XSS | 1     |
| MEDIUM   | 5.3  | Browsable Web Directories               | CGI abuses      | 1     |
| MEDIUM   | 5.0  | Backup Files Disclosure                 | CGI abuses      | 1     |
| MEDIUM   | 5.0  | CGI Generic Path Traversal (extended)   | CGI abuses      | 1     |
| MEDIUM   | 5.0  | Web Application Information Disclosure  | CGI abuses      | 1     |

## 7.3 Penjelasan Kerentanan Web Utama

### a) Remote File Inclusion (RFI) - CVSS 7.5

RFI memungkinkan penyerang menyuntikkan file dari server eksternal dan menjalankannya di server target. Sangat berbahaya karena dapat digunakan untuk web shell upload dan remote code execution.

### b) Local File Inclusion (LFI) - CVSS 6.8

LFI memungkinkan pembacaan file lokal sensitif seperti `/etc/passwd`, `/etc/shadow`, konfigurasi aplikasi, dan log files yang dapat digunakan sebagai foothold untuk eskalasi serangan.

### c) Tomcat Sample Application XSS

Aplikasi contoh Tomcat (`/examples/`) masih aktif dan mengandung kerentanan XSS pada parameter "time" di `cal2.jsp`. Aplikasi sample seharusnya dihapus dari environment production.

#### **d) Browsable Web Directories**

Directory listing aktif memungkinkan penyerang melihat seluruh struktur direktori web server dan menemukan file sensitif yang tidak seharusnya dapat diakses publik.

## 8. PERBANDINGAN ANTAR SCAN

### 8.1 Tabel Perbandingan

| Scan                  | Durasi | Critical | High | Medium | Low | Total    | Remediasi |
|-----------------------|--------|----------|------|--------|-----|----------|-----------|
| Host Discovery        | 7 mnt  | -        | -    | -      | -   | 3 (Info) | N/A       |
| Basic Network Scan    | 4 jam  | 10       | 9    | 40     | 11  | 95       | 3         |
| Advanced Scan         | 1 jam  | 11       | 9    | 34     | 13  | 88       | 5         |
| Web Application Tests | 7 jam  | 4        | 4    | 18     | -   | 38       | 2         |

### 8.2 Insight Perbandingan

- Advanced Scan paling efisien: hanya 1 jam tetapi menemukan paling banyak Critical (11)
- Basic Network Scan paling komprehensif (95 temuan) namun memakan waktu 4 jam
- Web Application Tests ideal untuk memetakan attack surface web secara khusus (LFI/RFI/XSS/Path Traversal)
- Untuk pentest lengkap: kombinasikan Advanced Scan + Web Application Tests
- Scan unauthenticated saja sudah menemukan puluhan Critical - credentialed scan akan jauh lebih banyak lagi



## 9. REKOMENDASI REMEDIASI

### 9.1 Prioritas Critical & High

| No | Vulnerability               | Risiko                            | Rekomendasi                                                                           |
|----|-----------------------------|-----------------------------------|---------------------------------------------------------------------------------------|
| 1  | <b>Ubuntu 8.04 EOL</b>      | Tidak ada patch untuk CVE baru    | Upgrade ke Ubuntu 22.04 LTS atau distro yang masih dalam support aktif                |
| 2  | <b>VNC Password Default</b> | Remote takeover tanpa bruteforce  | Ganti password VNC, gunakan password minimal 16 karakter, batasi akses via firewall   |
| 3  | <b>SSL v2/v3 Protocol</b>   | POODLE, DROWN attack              | Disable SSL v2/v3, aktifkan TLS 1.2 minimum, preferably TLS 1.3                       |
| 4  | <b>Bind Shell Backdoor</b>  | Akses root tanpa autentikasi      | Hapus backdoor, audit semua proses yang berjalan, lakukan full forensic investigation |
| 5  | <b>rlogin / rsh Service</b> | Autentikasi tidak aman, plaintext | Disable rlogin/rsh/rexec sepenuhnya, gunakan SSH sebagai satu-satunya akses remote    |
| 6  | <b>Samba Badlock</b>        | Privilege escalation via SMB      | Update Samba ke versi terbaru yang sudah dipatch untuk CVE-2016-2118                  |
| 7  | <b>CGI RFI / LFI</b>        | Remote/local file inclusion, RCE  | Nonaktifkan allow_url_include di PHP, validasi semua input, gunakan WAF               |
| 8  | <b>NFS World Readable</b>   | Data exfiltration via NFS mount   | Restrict NFS exports di /etc/exports, gunakan auth_sys atau Kerberos                  |

### 9.2 Prioritas Medium

- Nonaktifkan directory listing: tambahkan "Options -Indexes" di konfigurasi Apache
- Hapus backup files dan temporary files dari web root directory
- Hapus semua Tomcat sample applications dari /examples/ dan /manager/
- Konfigurasi phpMyAdmin: restrict akses ke IP tertentu dan gunakan strong password
- Update PHP ke versi yang masih dalam active support (PHP 8.x)
- Konfigurasikan Content Security Policy (CSP) header untuk mitigasi XSS

## 10. KESIMPULAN

---

### 10.1 Temuan Utama

Vulnerability Assessment menggunakan Nessus Essentials terhadap Metasploitable 2 berhasil mengidentifikasi kerentanan yang sangat parah di semua lapisan sistem:

- Attack surface sangat luas: 34+ port terbuka termasuk layanan berbahaya (Telnet, rlogin, Backdoor Shell)
- OS sudah EOL: Ubuntu 8.04 tidak mendapat security patch sejak 2013, rentan terhadap ratusan CVE
- Backdoor aktif: port 1524 memberikan akses root shell langsung tanpa autentikasi apapun
- Kredensial default: VNC dengan password "password" dapat dieksploitasi dalam hitungan detik
- Web attack surface luas: RFI, LFI, XSS, Path Traversal, directory listing, dan backup file exposure

### 10.2 Evaluasi Nessus Essentials untuk Lab

Nessus Essentials terbukti efektif untuk pembelajaran dan lab environment:

- Plugin database selalu up-to-date dengan CVSS, VPR, dan EPSS scoring modern
- Empat tipe scan yang berbeda saling melengkapi untuk coverage yang komprehensif
- Interface intuitif dan mudah digunakan bahkan untuk pemula
- Keterbatasan utama untuk lab: tidak bisa export laporan gratis (workaround: screenshot manual)
- Sangat direkomendasikan untuk belajar VA/PT, home lab, dan persiapan sertifikasi

### 10.3 Pelajaran dari Lab ini

1. Selalu mulai dengan Host Discovery untuk memetakan attack surface sebelum scan mendalam
2. Advanced Scan lebih efisien dari Basic Scan untuk deep dive (1 jam vs 4 jam, temuan Critical lebih banyak)
3. Web Application Tests harus dijalankan terpisah untuk mendapat hasil web vulnerability yang komprehensif
4. Credentialed scan akan menghasilkan jauh lebih banyak temuan dibanding unauthenticated scan
5. Kombinasi terbaik untuk pentest nyata: Advanced Scan + Web Application Tests + Credentialed Scan

---

--- End of Report ---

Dibuat oleh: Fahmi Riansyah (fahmipentest) | Project Meta2 | Lab Internal | Confidential